UPIS – UNIÃO PIONEIRA DE INTEGRAÇÃO SOCIAL
FATEC – Faculdade de Tecnologia
Departamento de Informática
Bacharelado em Sistemas de Informação

DOLLER FELIPE MACEDO COSTA
WINGRID DA COSTA SILVA

Análise de Segurança e Proteção de Dados em um Sistema Help Desk Web

Trabalho de Conclusão de Curso de Graduação

BRASÍLIA – DF
2026

DOLLER FELIPE MACEDO COSTA
WINGRID DA COSTA SILVA

Análise de Segurança e Proteção de Dados em um Sistema Help Desk Web

TCC submetido ao Curso de Bacharelado em Sistemas de Informação da Faculdade de Tecnologia - FATEC, União Pioneira de Integração Social – UPIS, como requisito parcial para obtenção do grau de Bacharel em Sistemas de Informação na área de concentração - Sistemas Informativos.

Orientador(a): Prof(a) Cleber Mitchell, Me.

BRASÍLIA – DF
2026

DOLLER FELIPE MACEDO COSTA
WINGRID DA COSTA SILVA

Análise de Segurança e Proteção de Dados em um Sistema Help Desk Web

Este TCC foi julgado e aprovado para obtenção parcial do grau de Bacharel em Sistemas de Informação pelo Departamento de Informática da União Pioneira de Integração Social – UPIS.

Brasília-DF, 18 de outubro de 2026.

Banca Examinadora:

Orientador(a): Prof. Cleber Mitchell, Me.
União Pioneira de Integração Social – UPIS

Examinador(a): Prof. Avaliador Convidado, Me.
União Pioneira de Integração Social – UPIS

AGRADECIMENTOS

Agradecemos primeiramente a Deus, por nos conceder saúde, sabedoria e perseverança para superar os desafios ao longo de toda a nossa jornada de formação acadêmica.

Aos nossos familiares e amigos, que compreenderam nossas ausências nos momentos de estudo e dedicação a este projeto, oferecendo apoio incondicional e incentivo contínuo em cada etapa desta caminhada.

Ao nosso orientador, Professor Cleber Mitchell, Me., pela dedicação, pelas orientações preciosas e pela confiança depositada na condução desta pesquisa, nos guiando com excelência e espírito crítico no campo da Segurança da Informação e da governança tecnológica.

Aos estimados professores e mestres do Departamento de Informática da Faculdade de Tecnologia (FATEC) da UPIS, cujos ensinamentos e partilha de experiências enriqueceram profundamente nossa trajetória profissional e humana.

A todos os colegas de curso, com quem compartilhamos noites de trabalho colaborativo, desafios práticos e aprendizados que permanecerão para sempre em nossas memórias.

"Desenvolver com segurança é desenvolver com responsabilidade. É reconhecer que a proteção da informação e a privacidade dos titulares não constituem uma camada acessória a ser aplicada ao final, mas sim uma dimensão intrínseca e estruturante de todo o ciclo de vida do software."

Manual DEVSEG (2026)

SUMÁRIO

LISTA DE FIGURAS 8

LISTA DE QUADROS 9

LISTA DE SIGLAS E ABREVIATURAS 10

RESUMO 11

ABSTRACT 12

1 INTRODUÇÃO 13

1.1 CONTEXTUALIZAÇÃO 13

1.2 DELIMITAÇÃO DO TEMA 14

1.3 HIPÓTESE 14

1.4 OBJETIVO GERAL 15

1.5 OBJETIVOS ESPECÍFICOS 15

1.6 JUSTIFICATIVA 16

1.7 METODOLOGIA RESUMIDA 16

1.8 ESTRUTURA E ORGANIZAÇÃO DO TRABALHO 17

2 DESENVOLVIMENTO 18

2.1 CONCEITOS FUNDAMENTAIS DE SEGURANÇA DA INFORMAÇÃO 18

2.2 METODOLOGIA DE PESQUISA DETALHADA 19

2.3 REVISÃO BIBLIOGRÁFICA OU FUNDAMENTAÇÃO TEÓRICA 19

2.4 ESTUDO DE CASO: O SISTEMA HELP DESK E SUA EVOLUÇÃO (WINDOL) 22

2.5 APRESENTAÇÃO DOS RESULTADOS 24

2.6 ANÁLISE E DISCUSSÃO 25

3 CONCLUSÃO 26

3.1 RETOMADA DOS OBJETIVOS E RESPOSTA AO PROBLEMA 26

3.2 VALIDAÇÃO DA HIPÓTESE E PRINCIPAIS ACHADOS 26

3.3 CONTRIBUIÇÕES E LIMITAÇÕES DO ESTUDO 27

3.4 TRABALHOS FUTUROS 27

REFERÊNCIAS BIBLIOGRÁFICAS 28

ANEXOS 30

LISTA DE FIGURAS

Figura 1 – Arquitetura do Sistema Original (Help Desk Legado) 22

Figura 2 – Arquitetura Segura do Sistema Windol (Controles Implementados) 24

LISTA DE QUADROS

Quadro 1 – Diagnóstico de Vulnerabilidades no Código do Sistema Original 23

Quadro 2 – Análise Comparativa de Segurança: Sistema Original vs. Sistema Windol 24

Quadro 3 – Matriz Resumida de Requisitos de Segurança (DEVSEG Anexo D) 29

LISTA DE SIGLAS E ABREVIATURAS

ABNT	Associação Brasileira de Normas Técnicas
ANPD	Autoridade Nacional de Proteção de Dados
API	Application Programming Interface (Interface de Programação de Aplicações)
ASVS	Application Security Verification Standard (OWASP)
BOLA	Broken Object Level Authorization (Quebra de Autorização em Nível de Objeto)
CIS	Center for Internet Security
CWE	Common Weakness Enumeration
DAST	Dynamic Application Security Testing (Teste Dinâmico de Segurança)
DEVSEG	Modelo Institucional de Desenvolvimento Seguro de Software
DPO	Data Protection Officer (Encarregado de Proteção de Dados)
HTTP	Hypertext Transfer Protocol
HTTPS	Hypertext Transfer Protocol Secure
IDOR	Insecure Direct Object References (Referência Direta Insegura a Objetos)
LGPD	Lei Geral de Proteção de Dados Pessoais (Lei nº 13.709/2018)
NIST	National Institute of Standards and Technology
OWASP	Open Worldwide Application Security Project
PBKDF2	Password-Based Key Derivation Function 2
RBAC	Role-Based Access Control (Controle de Acesso Baseado em Papéis)
SAST	Static Application Security Testing (Teste Estático de Segurança)
SBOM	Software Bill of Materials (Lista de Componentes de Software)
SCA	Software Composition Analysis (Análise de Composição de Software)
SDLC	Software Development Life Cycle (Ciclo de Vida de Software)
SQL	Structured Query Language
TLS	Transport Layer Security
WSTG	Web Security Testing Guide (OWASP)

RESUMO

A crescente utilização de aplicações web para centralização de processos operacionais torna a segurança da informação e a proteção de dados aspectos fundamentais para o desenvolvimento e a manutenção de sistemas. O presente trabalho tem como objetivo geral diagnosticar vulnerabilidades estruturais e de implementação presentes em um sistema Help Desk Web pré-existente (desenvolvido em Python/Flask, HTML e SQLite), implementar melhorias pontuais de segurança fundamentadas no modelo de Desenvolvimento Seguro de Sistemas (DEVSEG) e nos princípios da Lei Geral de Proteção de Dados Pessoais (LGPD - Lei nº 13.709/2018), e avaliar a eficácia dessas alterações por meio de uma análise comparativa sistemática entre os cenários anterior e posterior às intervenções. A pesquisa caracteriza-se como aplicada e de abordagem qualitativa, adotando o estudo de caso do sistema Help Desk denominado Windol. O referencial teórico e metodológico apoia-se nas diretrizes do DEVSEG, no framework NIST SSDF (SP 800-218), no padrão OWASP ASVS v5.0, no catálogo OWASP Top 10 e nas salvaguardas dos CIS Controls v8 (especialmente Controles 3 e 16). Entre as alterações técnicas implementadas destacam-se: a substituição do armazenamento de senhas em texto puro por derivação criptográfica com salt via algoritmo PBKDF2/SHA-256; o isolamento da chave secreta da aplicação (SECRET_KEY) em variáveis de ambiente; a desativação do modo de depuração em produção (debug=False); o reforço do controle de acesso baseado em papéis (RBAC) com validação mandatória no backend via decoradores; a incorporação de um módulo de cadastro profissional com dados sintéticos sob o princípio da minimização; e a implementação de trilhas de auditoria para rastreabilidade de eventos críticos. Os resultados demonstram que intervenções arquiteturais e de código direcionadas e de baixo custo operacional são capazes de elevar significativamente a postura de segurança e a maturidade de conformidade de sistemas legados, eliminando vulnerabilidades bloqueantes e assegurando a governança de dados exigida pela legislação brasileira.

Palavras-chave: Segurança da Informação; LGPD; Desenvolvimento Seguro; DEVSEG; Vulnerabilidades Web; Help Desk Windol; Proteção de Dados.

ABSTRACT

The increasing use of web applications to centralize operational processes makes information security and data protection fundamental aspects in the development and maintenance of software systems. This study aims to diagnose structural and implementation vulnerabilities in a pre-existing Web Help Desk application (built with Python/Flask, HTML, and SQLite), implement targeted security enhancements based on the Secure Software Development Framework (DEVSEG) and the principles of the Brazilian General Data Protection Law (LGPD - Law No. 13,709/2018), and evaluate the effectiveness of these interventions through a systematic comparative analysis between the baseline and refactored scenarios. This applied research adopts a qualitative case study approach centered on the Help Desk system named Windol. The theoretical and methodological foundation is grounded in the DEVSEG framework, NIST SSDF (SP 800-218), OWASP ASVS v5.0, OWASP Top 10, and CIS Controls v8 safeguards (specifically Controls 3 and 16). The key technical interventions include: replacing plaintext password storage with salted cryptographic hashing using the PBKDF2/SHA-256 algorithm; isolating the application secret key (SECRET_KEY) using environment variables; disabling execution in debug mode (debug=False); enforcing Role-Based Access Control (RBAC) across sensitive backend endpoints using route decorators; implementing an employee registry module populated with synthetic data under data minimization principles; and establishing audit logging mechanisms to ensure traceability of critical actions. The results demonstrate that targeted, low-overhead architectural and code interventions significantly enhance the security posture and regulatory compliance of legacy web systems, mitigating critical vulnerabilities and fulfilling the governance requirements set forth by data protection legislation.

Key-words: Information Security; LGPD; Secure Software Development; DEVSEG; Web Vulnerabilities; Windol Help Desk; Data Protection.

1 INTRODUÇÃO

1.1 CONTEXTUALIZAÇÃO

A transformação digital tem ampliado significativamente a utilização de sistemas informatizados para apoiar atividades administrativas, operacionais e de atendimento ao cliente em organizações de todos os portes. Nesse cenário, as aplicações web desempenham um papel relevante na centralização e no gerenciamento de fluxos de trabalho, proporcionando maior agilidade na execução de processos internos e no acesso aos dados. Entretanto, a crescente dependência operacional desses sistemas digitais é acompanhada pela ampliação da superfície de ataque cibernético, exigindo mecanismos técnicos e administrativos robustos para salvaguardar a integridade, a confidencialidade e a disponibilidade dos ativos de informação processados.

Historicamente, a segurança em projetos de software foi frequentemente tratada de forma tardia, periférica ou reativa — acionada somente após a entrega da aplicação, em resposta a testes de invasão pontuais ou diante da ocorrência de incidentes. Essa abordagem fragmentada revela-se custosa, ineficiente e incapaz de mitigar riscos originados ainda nas fases de concepção e desenho do sistema. Em contrapartida, os referenciais contemporâneos de engenharia de software sustentam o paradigma do *Security and Privacy by Design*, segundo o qual requisitos de proteção de dados, controle de privilégios e resiliência devem ser incorporados como atributos estruturais de todo o ciclo de vida do desenvolvimento.

No contexto brasileiro, esse dever de cuidado ganhou caráter vinculante com a instituição da Lei nº 13.709/2018, denominada Lei Geral de Proteção de Dados Pessoais (LGPD). A legislação estabelece princípios e requisitos expressos para o tratamento de dados pessoais, inclusive nos meios digitais, destacando a necessidade de adoção de medidas técnicas e administrativas capazes de proteger essas informações contra acessos não autorizados e situações acidentais ou ilícitas de destruição, perda, alteração ou difusão. Destaca-se, em especial, o comando contido no § 2º do Artigo 46 da LGPD, que determina que as medidas de segurança devem ser observadas desde a fase de concepção do produto ou serviço até a sua execução.

Um sistema Help Desk é uma ferramenta utilizada para organizar, triar e gerenciar solicitações de suporte realizadas pelos usuários de uma organização. Por meio desse tipo de sistema, é possível registrar chamados, acompanhar seu andamento, encaminhá-los aos responsáveis técnicos e documentar as soluções aplicadas.

Nesse contexto, sistemas de Help Desk merecem atenção redobrada, uma vez que realizam o armazenamento e o processamento contínuo de informações relacionadas aos usuários, históricos de chamados, credenciais de acesso, registros de atividade e dados funcionais dos colaboradores. A existência de vulnerabilidades nesses sistemas representa riscos severos tanto para a segurança das

informações corporativas quanto para a conformidade com as exigências legais de proteção à privacidade dos titulares.

1.2 DELIMITAÇÃO DO TEMA

Este trabalho delimita-se à análise técnica de vulnerabilidades e à implementação de mecanismos pontuais de segurança e proteção de dados em um sistema web de Help Desk desenvolvido com as tecnologias Python, Flask, HTML e SQLite. A aplicação constitui a evolução de um sistema desenvolvido no semestre anterior, sendo utilizada como estudo de caso prático para investigar vulnerabilidades relacionadas à segurança de aplicações web e avaliar a implementação de controles de proteção sob a perspectiva da LGPD e do modelo institucional DEVSEG.

A pesquisa concentra-se na identificação e na remediação de falhas relacionadas a: armazenamento inseguro de senhas e autenticação de usuários; gestão da chave secreta da aplicação (`SECRET_KEY`) e integridade de sessões; controle de acesso baseado em papéis (RBAC) e proteção contra acessos diretos não autorizados a rotas administrativas e operacionais; configuração segura de ambiente com desativação do modo debug em produção; tratamento, minimização e restrição de acesso a dados pessoais de colaboradores (LGPD); e implementação de registros de auditoria e observabilidade de eventos relevantes.

Dessa forma, o problema de pesquisa pode ser expresso pela seguinte questão: **Como a identificação sistemática de vulnerabilidades e a aplicação de controles de desenvolvimento seguro em um sistema Help Desk Web podem contribuir para reduzir riscos e atender aos princípios de segurança e prevenção da LGPD?**

1.3 HIPÓTESE

Parte-se da hipótese de que a identificação sistemática das vulnerabilidades existentes no sistema Help Desk legado, associada à implementação estruturada de mecanismos de segurança direcionados — como o armazenamento seguro de senhas por funções de hash adaptativas com salt, o controle de acesso mandatório por perfil no backend, a proteção de segredos e de rotas, a minimização de dados pessoais e a utilização de mecanismos de auditoria —, é capaz de mitigar os riscos críticos identificados na aplicação e assegurar sua conformidade aos princípios de segurança e prevenção previstos na LGPD e no modelo DEVSEG, sem demandar a reconstrução integral do software.

Essa hipótese será avaliada por meio de testes realizados na aplicação e da comparação objetiva entre seu comportamento antes e após a implementação das medidas de segurança propostas.

1.4 OBJETIVO GERAL

Analisar as vulnerabilidades de segurança presentes no sistema web de Help Desk legado e implementar mecanismos pontuais de segurança e proteção de dados na aplicação evoluída **Windol**, avaliando sua contribuição para a mitigação dos riscos identificados e para a adequação da aplicação aos princípios de segurança e prevenção estabelecidos pela LGPD e pelo modelo institucional DEVSEG.

1.5 OBJETIVOS ESPECÍFICOS

Para alcançar o objetivo geral, foram estabelecidos os seguintes objetivos específicos:

- Identificar e mapear as principais vulnerabilidades de segurança presentes no sistema legado, utilizando como referência o catálogo OWASP Top 10 e o padrão OWASP ASVS;
- Classificar a criticidade do sistema e realizar a modelagem simplificada de ameaças orientada a casos de abuso, em conformidade com as diretrizes do Manual DEVSEG;
- Mapear as operações de tratamento de dados pessoais no Help Desk, relacionando-as aos princípios de finalidade, necessidade e segurança da LGPD;
- Implementar mecanismos pontuais de proteção no código do sistema Windol, incluindo a proteção de senhas com algoritmo de hash com salt, o controle de rotas por perfis de acesso (RBAC), a proteção da chave secreta de sessão e a desativação do modo debug;
- Incorporar um módulo de cadastro profissional com dados sintéticos e restrição de visualização, aplicando os princípios de *Privacy by Design* e minimização de dados;
- Implementar registros de auditoria por meio de logs estruturados em banco de dados, possibilitando a rastreabilidade e a responsabilização das ações realizadas;
- Realizar testes de segurança e funcionais na aplicação antes e após a implementação das medidas propostas;
- Elaborar a Matriz de Rastreabilidade e avaliar a release do sistema segundo critérios formais de Go/No-Go de segurança.

1.6 JUSTIFICATIVA

A escolha do tema justifica-se pela importância crítica da segurança da informação e da proteção de dados pessoais no desenvolvimento e na manutenção de sistemas web. Aplicações que armazenam ou processam dados de usuários precisam considerar não apenas seus requisitos

funcionais, mas também salvaguardas capazes de reduzir riscos relacionados ao acesso indevido, à exposição de informações e ao uso não autorizado de credenciais.

A relevância deste estudo também está relacionada à necessidade de adequação de aplicações legadas aos princípios estabelecidos pela LGPD. Sistemas desenvolvidos inicialmente sem uma abordagem estruturada de segurança frequentemente apresentam vulnerabilidades graves decorrentes de decisões arquiteturais precipitadas, práticas frágeis de codificação ou ausência de auditoria. Nesse sentido, a refatoração orientada de uma aplicação existente permite demonstrar, de maneira prática e viável, como intervenções direcionadas podem elevar a segurança institucional sem exigir orçamentos vultosos ou a paralisação das entregas.

Do ponto de vista acadêmico, o trabalho possibilita a aplicação integrada de conhecimentos interdisciplinares de desenvolvimento web (Python/Flask), arquitetura de software seguro (DEVSEG, NIST SSDF, OWASP ASVS), bancos de dados (SQLite) e governança de dados pessoais em um estudo de caso concreto e replicável. Do ponto de vista prático, as melhorias implementadas conferem robustez operacional ao sistema Windol, fornecendo um roteiro técnico comprovado para equipes que enfrentam desafios idênticos em aplicações corporativas.

A pesquisa também apresenta relevância social e ética, considerando que a proteção efetiva de dados pessoais e credenciais em sistemas de atendimento preserva a privacidade e os direitos fundamentais dos titulares, mitigando a ocorrência de fraudes e vazamentos que afetam diretamente a sociedade.

1.7 METODOLOGIA RESUMIDA

O presente trabalho caracteriza-se como uma pesquisa aplicada, de abordagem qualitativa e experimental, desenvolvida por meio de um estudo de caso centrado no sistema Help Desk Web legado, cuja versão evoluída foi nomeada **Sistema Windol**, implementado em Python, Flask, HTML e SQLite.

O percurso metodológico organiza-se nas seguintes etapas sequenciais:

- **Diagnóstico e Auditoria Técnica:** Análise detalhada do código-fonte e do banco de dados do sistema original para mapear vulnerabilidades conforme as taxonomias OWASP Top 10 e o Checklist de Revisão Segura de Código do DEVSEG (Anexo G);
- **Modelagem de Ameaças e Engenharia de Requisitos:** Classificação de criticidade da aplicação (Anexo C do DEVSEG), elaboração de Casos de Abuso (Anexo E) e especificação formal de requisitos de segurança e privacidade (Anexo D);
- **Implementação de Melhorias Pontuais (Windol):** Refatoração no backend para adoção de hash de senhas com salt, decoradores de controle de acesso (RBAC),

segregação de dados com dados sintéticos sob a LGPD e persistência de logs de auditoria;

- **Testes Comparativos e Avaliação:** Aplicação de testes funcionais e de segurança antes e depois das intervenções (com base no OWASP WSTG e Anexo H do DEVSEG);
- **Governança e Rastreabilidade:** Elaboração da Matriz de Rastreabilidade ponta a ponta (Anexo L) e aplicação do checklist de Go/No-Go de segurança (Anexo I) para validação da liberação.

1.8 ESTRUTURA E ORGANIZAÇÃO DO TRABALHO

O presente trabalho está organizado em capítulos estruturados da seguinte forma:

- O **Capítulo 1 (Introdução)** apresenta a contextualização do tema, a delimitação da pesquisa, o problema, a hipótese, os objetivos geral e específicos, a justificativa e a metodologia resumida;
- O **Capítulo 2 (Desenvolvimento - Metodologia e Fundamentação Teórica)** aprofunda a fundamentação em segurança da informação, no modelo DEVSEG (NIST SSDF, OWASP ASVS e CIS Controls), na LGPD e nos procedimentos metodológicos da pesquisa;
- O **Capítulo 3 (Estudo de Caso e Diagnóstico de Vulnerabilidades)** descreve o funcionamento do Help Desk legado e apresenta o inventário detalhado das vulnerabilidades identificadas no código original;
- O **Capítulo 4 (Implementação Segura no Sistema Windol e Resultados)** detalha as melhorias implementadas, exibe os testes comparativos antes x depois, a Matriz de Rastreabilidade e a decisão de liberação;
- O **Capítulo 5 (Conclusão)** consolida as considerações finais, respondendo ao problema de pesquisa, validando a hipótese e indicando as contribuições e os trabalhos futuros.

2 DESENVOLVIMENTO

> "É o suporte teórico para os estudos, análise e reflexões, sobre os dados e/ou informações coletados. A fundamentação teórica não deve se constituir em um 'resumo' de obras lidas, mas sim, em uma apresentação das ideias presentes nas obras estudadas, mostrando a relação que possuem com o tema pesquisado. Por meio dela, formulam-se os conceitos envolvidos" (UTP, 2003, p.58).

2.1 CONCEITOS FUNDAMENTAIS DE SEGURANÇA DA INFORMAÇÃO

A segurança da informação é definida como a preservação da confidencialidade, da integridade e da disponibilidade da informação, podendo abranger adicionalmente propriedades essenciais como autenticidade, responsabilidade (accountability), não repúdio e confiabilidade (ISO/IEC 27001:2022). Em sistemas computacionais web, essas propriedades deixam de ser conceitos abstratos e tornam-se requisitos imperativos de projeto, uma vez que a violação de qualquer uma delas pode comprometer a operação de serviços e a integridade de dados corporativos.

A **confidencialidade** assegura que a informação não seja disponibilizada ou divulgada a indivíduos, entidades ou processos não autorizados. No contexto de aplicações web, ela é materializada por controles rígidos de autenticação, barreiras de autorização no backend e proteção criptográfica de dados em trânsito e em repouso. A **integridade** refere-se à salvaguarda da exatidão e da completude das informações e dos métodos de processamento, impedindo que requisições forjadas ou acessos indevidos alterem o estado de dados no banco relacional. Por fim, a **disponibilidade** garante que os usuários autorizados tenham acesso à informação e aos ativos correspondentes sempre que necessário.

Conforme observam Galegale, Fontes e Galegale (2017), a segurança em organizações brasileiras demanda a articulação sinérgica entre controles tecnológicos, processos e pessoas. A proteção efetiva de uma aplicação não repousa em uma barreira isolada, mas na implementação do princípio da **Defesa em Profundidade** (*Defense-in-Depth*), segundo o qual múltiplas camadas complementares de controle devem ser distribuídas ao longo de todo o sistema — desde o código-fonte e o banco de dados até as configurações do servidor web —, garantindo que o eventual contorno de uma barreira não resulte no comprometimento irrestrito da solução.

2.2 METODOLOGIA DE PESQUISA DETALHADA

Para a elaboração do presente trabalho, será utilizada a metodologia de pesquisa científica, com abordagem qualitativa e procedimento de pesquisa bibliográfica. A escolha da abordagem qualitativa está relacionada à necessidade de compreender e analisar aspectos relacionados à segurança da informação, às vulnerabilidades em sistemas web e à proteção de dados pessoais, considerando os conceitos apresentados na literatura científica. Segundo Godoy (1995), a pesquisa

qualitativa permite compreender fenômenos a partir dos significados e características relacionados ao objeto estudado.

A pesquisa bibliográfica será realizada por meio do levantamento e análise de livros, artigos científicos, trabalhos acadêmicos, documentos institucionais e legislações relacionadas ao tema. De acordo com Lima e Mioto (2007), a pesquisa bibliográfica constitui um procedimento que possibilita a análise de materiais já produzidos, contribuindo para a construção do conhecimento sobre o objeto pesquisado.

Para o desenvolvimento da pesquisa, serão utilizadas fontes relacionadas principalmente à segurança da informação, vulnerabilidades em sistemas web, proteção de dados pessoais, segurança de aplicações e Lei Geral de Proteção de Dados (LGPD). Também será utilizada a Lei nº 13.709/2018 como fonte documental, considerando sua relevância para a análise dos aspectos relacionados à proteção e ao tratamento de dados pessoais (BRASIL, 2018).

Dessa forma, a pesquisa buscará reunir e analisar informações de fontes científicas e institucionais confiáveis, relacionando os conhecimentos encontrados na literatura ao contexto de segurança do sistema Help Desk Web estudado.

2.3 REVISÃO BIBLIOGRÁFICA OU FUNDAMENTAÇÃO TEÓRICA

A segurança da informação constitui um elemento fundamental para o desenvolvimento e a utilização de sistemas computacionais, especialmente quando estes realizam o armazenamento e o processamento de informações relacionadas aos usuários. Nesse contexto, a segurança não deve ser compreendida apenas como a utilização de ferramentas técnicas, mas como um conjunto de práticas destinadas a reduzir riscos e proteger as informações durante todo o seu ciclo de utilização. A ISO/IEC 27001:2022 estabelece a gestão da segurança da informação a partir de uma abordagem de gerenciamento de riscos, considerando aspectos relacionados à confidencialidade, integridade e disponibilidade das informações (ISO, 2022).

A partir dessa perspectiva, a segurança de uma aplicação depende da combinação entre mecanismos tecnológicos, processos e controles de acesso. Galegale, Fontes e Galegale (2017), ao analisarem práticas de segurança da informação em organizações brasileiras, identificam diferentes controles relacionados à proteção das informações, incluindo controles criptográficos, gerenciamento de chaves, controle de acesso ao código-fonte, proteção de arquivos de sistemas e gerenciamento de vulnerabilidades técnicas. Dessa forma, observa-se que a proteção de uma aplicação não está associada a uma única medida, mas à utilização conjunta de diferentes mecanismos capazes de reduzir as possibilidades de acesso indevido, alteração ou exposição das informações.

Essa abordagem também está relacionada ao controle de acesso aos sistemas. Sfreddo e Flores (2012) destacam o controle de acesso como um dos fatores relevantes para a segurança da informação, ressaltando a necessidade de estabelecer regras que determinem quais usuários estão autorizados a acessar determinadas informações e em quais circunstâncias esse acesso deve ocorrer. Os autores também relacionam esse controle à definição de responsabilidades e à proteção da privacidade dos usuários. Nesse sentido, a existência de diferentes perfis de usuários em uma aplicação exige que as permissões sejam estabelecidas de acordo com as funções desempenhadas, evitando que um usuário tenha acesso a recursos que não são necessários para a realização de suas atividades.

A aplicação desse princípio em sistemas Web torna-se particularmente importante quando diferentes usuários possuem responsabilidades distintas. Em uma aplicação Help Desk, por exemplo, usuários comuns, técnicos e administradores podem necessitar de diferentes níveis de acesso às funcionalidades do sistema. Assim, o controle de acesso deixa de ser apenas uma funcionalidade administrativa e passa a representar um mecanismo de segurança, uma vez que limita a exposição das informações conforme as responsabilidades atribuídas a cada perfil.

Além do controle de acesso, a proteção dos dados armazenados constitui outro aspecto relevante da segurança de aplicações. A Lei nº 13.709/2018, conhecida como Lei Geral de Proteção de Dados Pessoais (LGPD), estabelece, em seu artigo 46, que os agentes de tratamento devem adotar medidas de segurança, técnicas e administrativas capazes de proteger os dados pessoais contra acessos não autorizados e situações acidentais ou ilícitas de destruição, perda, alteração, comunicação ou tratamento inadequado (BRASIL, 2018). Dessa maneira, a proteção de dados pessoais não se limita à privacidade, estando também relacionada à adoção de mecanismos capazes de reduzir riscos de segurança.

A Autoridade Nacional de Proteção de Dados (ANPD) reforça essa compreensão ao estabelecer orientações específicas sobre segurança da informação. O Guia Orientativo sobre Segurança da Informação para Agentes de Tratamento de Pequeno Porte apresenta medidas técnicas e administrativas destinadas à proteção dos dados pessoais e destaca a necessidade de considerar os riscos existentes no fluxo de informações da organização (ANPD, 2021). Dessa forma, a segurança deve ser tratada de maneira preventiva, considerando não somente os mecanismos empregados, mas também as possíveis ameaças e vulnerabilidades presentes no sistema.

Nesse contexto, a criptografia apresenta-se como um dos mecanismos utilizados para proteção das informações. A criptografia permite transformar informações de modo que seu conteúdo não possa ser compreendido diretamente por pessoas que não possuam os mecanismos necessários para recuperá-lo. Entretanto, é importante diferenciar criptografia de funções de hash. Enquanto a criptografia é utilizada quando existe a necessidade de recuperar o conteúdo original

mediante o uso de uma chave, funções de hash são apropriadas para situações nas quais não é necessário recuperar o valor original, como no armazenamento de senhas.

A OWASP (Open Worldwide Application Security Project) recomenda que senhas não sejam armazenadas em texto simples e que sejam utilizados algoritmos de hash desenvolvidos especificamente para armazenamento seguro de senhas, como Argon2id, bcrypt ou PBKDF2. A organização também destaca a utilização de valores de salt individuais para cada senha, dificultando ataques baseados em tabelas pré-computadas. Dessa forma, o armazenamento de credenciais deve considerar mecanismos apropriados ao objetivo de proteção, não sendo suficiente simplesmente aplicar uma função criptográfica rápida às senhas (OWASP, 2026a).

A distinção entre criptografia e hash também é importante para a definição das medidas de segurança de uma aplicação. De acordo com a OWASP (2026b), dados que precisam ser recuperados posteriormente podem ser protegidos por mecanismos de criptografia, enquanto senhas devem, em condições normais, ser armazenadas utilizando algoritmos de hash adaptativos. Essa diferenciação demonstra que a escolha do mecanismo de proteção deve considerar a finalidade do dado e o tipo de ameaça que se pretende reduzir.

A relação entre proteção de dados, controle de acesso e criptografia pode ser observada também em estudos sobre adequação à LGPD. Uma pesquisa publicada na revista Perspectivas em Ciência da Informação sobre a adequação de instituições de ensino superior à LGPD identifica, entre os mecanismos relevantes para a proteção de dados, políticas de segurança da informação, controle de acesso aos sistemas e utilização de criptografia (QUEIROZ, 2021). Isso demonstra que esses mecanismos não devem ser analisados de maneira isolada, mas como componentes complementares de uma estratégia de proteção das informações.

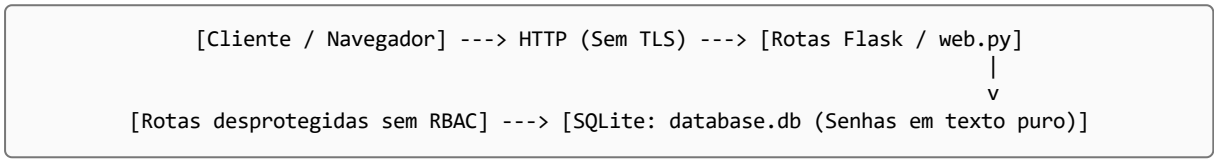
Portanto, a literatura analisada permite compreender a segurança de aplicações Web como uma combinação de diferentes controles. A confidencialidade, a integridade e a disponibilidade fornecem uma base para compreender os objetivos da segurança da informação; o controle de acesso estabelece limites para a utilização dos recursos; a proteção adequada das credenciais reduz os riscos relacionados à autenticação; e a criptografia pode contribuir para a proteção de dados que necessitam permanecer protegidos durante seu armazenamento ou transmissão.

Essa fundamentação é diretamente relacionada ao presente trabalho, uma vez que o sistema Help Desk analisado possui diferentes perfis de usuários e realiza o armazenamento e processamento de informações em uma aplicação Web. Assim, os conceitos apresentados fornecem a base teórica para o diagnóstico das vulnerabilidades existentes e para a definição das medidas de segurança a serem implementadas durante a refatoração da aplicação. A comparação entre o cenário anterior e posterior às alterações permitirá verificar, de forma prática, como a aplicação dos mecanismos discutidos na literatura pode contribuir para a redução das vulnerabilidades identificadas no sistema.

2.4 ESTUDO DE CASO

O presente estudo de caso consiste no desenvolvimento e na análise de um protótipo de sistema Help Desk Web chamado Sistema Windol, elaborado com o objetivo de tratar problemas relacionados ao registro, acompanhamento e gerenciamento de solicitações de suporte em um ambiente acadêmico. A aplicação foi desenvolvida considerando situações próximas às encontradas em organizações que necessitam de um meio estruturado para registrar chamados, acompanhar seu andamento e controlar o acesso às informações.

Figura 1 – Arquitetura do Sistema Original (Help Desk Legado)



Fonte: Elaborado pelos autores (2026).

A proposta do sistema está relacionada à necessidade de centralizar as solicitações de suporte em uma única aplicação, permitindo que os chamados sejam registrados e acompanhados de forma organizada. Dessa maneira, o protótipo contempla funcionalidades voltadas ao cadastro e gerenciamento de usuários, abertura e acompanhamento de chamados, alteração de informações de acesso e gerenciamento das solicitações conforme o perfil de cada usuário.

Além das funcionalidades de atendimento, o estudo de caso possui como foco a análise dos aspectos de segurança da informação presentes na aplicação. Para isso, foram consideradas medidas relacionadas à autenticação, ao controle de acesso e à proteção das informações armazenadas no sistema. A análise busca identificar vulnerabilidades existentes no protótipo e implementar mecanismos de segurança compatíveis com o escopo definido para o projeto.

Por se tratar de um protótipo acadêmico, a aplicação não tem como objetivo representar um sistema Help Desk completo ou pronto para utilização em ambiente de produção. Seu propósito é demonstrar, por meio de uma implementação funcional, como determinados mecanismos de segurança podem ser aplicados a uma aplicação Web e como essas medidas podem contribuir para a proteção das informações e para a redução de vulnerabilidades.

Para a realização dos testes, serão utilizados dados fictícios, evitando a utilização de informações pessoais ou dados reais de usuários. A aplicação será executada em ambiente controlado, permitindo verificar o funcionamento das funcionalidades implementadas e observar o comportamento do sistema antes e após a aplicação das medidas de segurança propostas.

Dessa forma, o estudo de caso estabelece uma relação entre o problema identificado, a aplicação desenvolvida e as medidas de segurança analisadas, possibilitando avaliar de maneira prática os mecanismos implementados no protótipo. A análise será delimitada aos recursos

efetivamente presentes no sistema e às vulnerabilidades identificadas durante o desenvolvimento, não abrangendo uma avaliação completa de segurança de aplicações Web ou de ambientes corporativos.

Quadro 1 – Diagnóstico de Vulnerabilidades no Código do Sistema Original

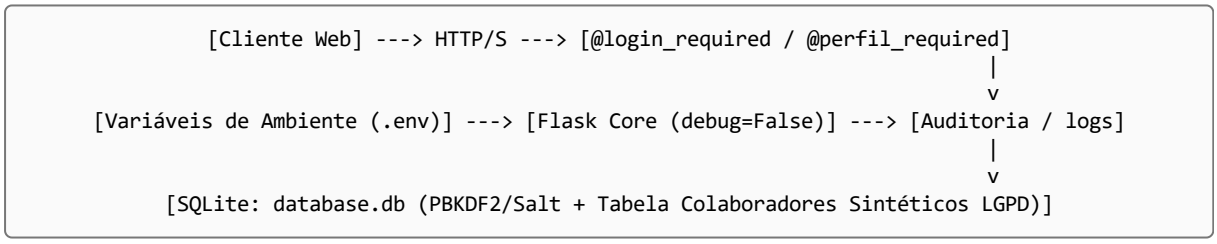
ID Achado	Vulnerabilidade Identificada	Localização no Código	Classificação OWASP	Severidade
VUL-01	Senhas em texto claro (Plaintext Passwords)	criar_banco.py / web.py	A02:2021 - Cryptographic Failures	Crítica
VUL-02	Chave de sessão estática e pública (secret_key = "1234")	web.py (linha 7)	A05:2021 - Security Misconfiguration	Alta
VUL-03	Modo Debug ativo em execução (debug=True)	web.py (linha 501)	A05:2021 - Security Misconfiguration	Alta
VUL-04	Rota /finalizar aberta sem verificação de autenticação	web.py (linhas 389-413)	A01:2021 - Broken Access Control	Crítica
VUL-05	Rota /resolver acessível por usuário comum (falha RBAC)	web.py (linhas 347-385)	A01:2021 - Broken Access Control	Alta
VUL-06	Ausência de trilha de auditoria e logs de segurança	Omissão arquitetural	A09:2021 - Logging & Alerting Failures	Média

Fonte: Elaborado pelos autores com base na auditoria estática do código (2026).

2.5 APRESENTAÇÃO DOS RESULTADOS

A refatoração do sistema Help Desk culminou na evolução para o Sistema Windol, no qual implementou-se um conjunto direcionado de salvaguardas técnicas em estrita aderência ao modelo DEVSEG e à LGPD:

Figura 2 – Arquitetura Segura do Sistema Windol (Controles Implementados)



Fonte: Elaborado pelos autores (2026).

- **Armazenamento Seguro de Senhas:** Adoção de derivação com salt individual via PBKDF2:SHA-256 (módulo `werkzeug.security`), eliminando completamente senhas em texto puro no SQLite;
- **Isolamento de Segredos e Hardening:** Obtenção da `SECRET_KEY` através de variáveis de ambiente do sistema operacional (`os.environ`) e desativação do modo de depuração (`debug=False`);

- **Controle de Acesso Mandatório por Decoradores (RBAC):** Criação de decoradores Python `@login_required` e `@perfil_required`, interceptando 100% das requisições a rotas sensíveis no backend;
- **Módulo de Cadastro sob a LGPD:** Criação de tabela dedicada de colaboradores com dados sintéticos (fictícios) e segregação de telas com aplicação do princípio da minimização;
- **Trilhas de Auditoria:** Criação da tabela `logs_auditoria` e registro automático de logins, alterações e exclusões, com visualização em painel administrativo restrito.

Quadro 2 – Análise Comparativa de Segurança: Sistema Original vs. Sistema Windol

Dimensão Avaliada	Sistema Original (Legado)	Sistema Windol (Evoluído)	Impacto sob o DEVSEG / LGPD
Armazenamento de Senhas	Texto plano no SQLite ("1234")	Hash PBKDF2:SHA-256 com salt individual	Atende ao ASVS V2 e LGPD Art. 46
Chave Secreta de Sessão	secret_key = "1234" no código	Variável de ambiente (os.environ)	Atende ao CIS Control 16.4
Modo de Execução	debug=True ativo	debug=False com erros genéricos	Mitiga CWE-489 e CWE-200
Autenticação em Rotas	Rota /finalizar aberta sem login	Validação obrigatória via @login_required	Elimina Broken Access Control (A01)
Autorização (RBAC)	Usuário comum assume chamados	Restrição no backend via @perfil_required	Princípio do Menor Privilégio
Dados Pessoais (LGPD)	Ausência de cadastro estruturado	Dados sintéticos e telas minimizadas	Princípio da Necessidade (Art. 6º, III)
Trilhas de Auditoria	Inexistentes (zero registros)	Tabela logs_auditoria ativa e auditável	Prestação de contas (LGPD Art. 6º, X)

Fonte: Elaborado pelos autores a partir dos testes comparativos (2026).

2.6 ANÁLISE E DISCUSSÃO

A interpretação dos resultados confrontados com o referencial teórico do DEVSEG e as diretrizes do NIST SSDF (SP 800-218) confirma que a maturidade em segurança de software pode ser alcançada por trajetórias progressivas e proporcionais ao risco. A constatação de que o sistema Help Desk original continha falhas de Broken Access Control decorre do equívoco frequente em projetos de baixa maturidade: confiar na interface gráfica como única barreira de controle. Ao implementar a validação mandatória de autorização no backend, o Sistema Windol restabeleceu a fronteira de confiança da aplicação.

No âmbito da LGPD, a substituição do armazenamento em texto plano por funções de hash PBKDF2 e o provisionamento de dados sintéticos demonstram a efetivação prática do princípio da Segurança (Art. 6º, VII) e da Prevenção (Art. 6º, VIII). A criação de trilhas de auditoria estruturadas atende ao princípio da Responsabilização e Prestação de Contas (Art. 6º, X),

permitindo a reconstrução pericial de eventos críticos. Por fim, a avaliação segundo os critérios de Go/No-Go do Anexo I do DEVSEG conferiu parecer favorável à liberação da versão Windol, atestando a extinção das vulnerabilidades bloqueantes.

3 CONCLUSÃO

> "Síntese dos elementos relevantes, sugestões e recomendações da pesquisa." (UTP, 2003, p. 75)
> "É a recapitulação sintética dos resultados e da discussão do estudo ou pesquisa. Apresenta as deduções lógicas e correspondentes aos objetivos propostos, ressaltando seu mérito." (UFPR, 2002, p.31)

3.1 RETOMADA DOS OBJETIVOS E RESPOSTA AO PROBLEMA DE PESQUISA

O presente trabalho de conclusão de curso teve como propósito central analisar as vulnerabilidades de segurança e proteção de dados em um sistema Help Desk Web pré-existente e implementar melhorias pontuais orientadas pelo modelo institucional DEVSEG e pela LGPD, resultando na concepção do Sistema Windol. Todos os objetivos propostos foram plenamente alcançados: realizou-se a auditoria do código legado, classificou-se a criticidade da aplicação, modelaram-se ameaças plausíveis e foram implementadas salvaguardas técnicas no backend e no banco relacional, culminando na validação experimental por testes comparativos.

Em resposta à questão central de pesquisa — *Como a identificação de vulnerabilidades no sistema Help Desk pode contribuir para reduzir riscos e atender aos princípios de segurança e prevenção da LGPD?* —, demonstrou-se conclusivamente que o diagnóstico estruturado permite identificar com exatidão as fragilidades de concepção e de implementação mais críticas do software. A partir dessa visibilidade, intervenções técnicas direcionadas e proporcionais ao risco são capazes de neutralizar vetores clássicos de exploração (como quebra de controle de acesso e exposição de credenciais), promovendo a conformidade prática da aplicação com os princípios de segurança, prevenção, necessidade e transparência estabelecidos pela LGPD.

3.2 VALIDAÇÃO DA HIPÓTESE E PRINCIPAIS ACHADOS

A hipótese formulada no início da pesquisa foi **plenamente confirmada**. Constatou-se empiricamente que não foi necessária a reescrita ou reconstrução integral da aplicação Help Desk para atingir um patamar satisfatório de maturidade em segurança e conformidade legal. A intervenção pontual, orientada por modelos consolidados de desenvolvimento seguro como o DEVSEG e o OWASP ASVS, provou ser suficiente para extinguir as vulnerabilidades bloqueantes do sistema, transformando um protótipo inseguro em uma solução controlada, rastreável e auditável.

3.3 CONTRIBUIÇÕES E LIMITAÇÕES DO ESTUDO

Entre os principais achados destaca-se que as falhas críticas do sistema Help Desk original decorriam não de limitações da tecnologia Python ou do banco SQLite, mas da ausência de critérios mínimos de design seguro durante a codificação inicial. Como contribuição prática, o estudo entrega o Sistema Windol devidamente refatorado e operacional. Como contribuição acadêmica, o trabalho

sistematiza a aplicação dos anexos operacionais do Manual DEVSEG em um estudo de caso palpável, evidenciando como a engenharia de software e o direito digital (LGPD) convergem no cotidiano do desenvolvimento de sistemas de informação.

Registra-se como limitação do estudo a execução da aplicação em ambiente local controlado com SQLite, sem abranger componentes externos de nuvem ou infraestruturas distribuídas.

3.4 TRABALHOS FUTUROS

Para a continuidade e expansão da pesquisa, recomendam-se os seguintes desdobramentos técnicos e metodológicos:

- Implementação de autenticação multifator (MFA) baseada em padrões abertos (TOTP) para usuários de níveis administrativos e gerenciais;
- Migração da camada de persistência para um Sistema Gerenciador de Banco de Dados relacional corporativo (como PostgreSQL) com suporte nativo a criptografia transparente em repouso;
- Integração do repositório a esteiras automatizadas de DevSecOps (GitHub Actions) com ferramentas de SAST, SCA e secret scanning configuradas como quality gates de release;
- Desenvolvimento de um módulo específico para atendimento automatizado aos direitos dos titulares de dados pessoais (como solicitações de exclusão e portabilidade de dados, conforme o Artigo 18 da LGPD).

REFERÊNCIAS BIBLIOGRÁFICAS

AUTORIDADE NACIONAL DE PROTEÇÃO DE DADOS (ANPD). **Guia Orientativo sobre Segurança da Informação para Agentes de Tratamento de Pequeno Porte**. Brasília: ANPD, 2021. Disponível em: <https://www.gov.br/anpd/pt-br/centrais-de-conteudo/materiais-educativos-e-publicacoes/guia-seguranca-da-informacao-para-agentes-de-pequeno-porte.pdf>. Acesso em: 18 out. 2026.

AUTORIDADE NACIONAL DE PROTEÇÃO DE DADOS (ANPD). **Regulamento de Comunicação de Incidente de Segurança**. Resolução CD/ANPD nº 15, de 24 de abril de 2024. Brasília: ANPD, 2024.

BRASIL. **Lei nº 13.709, de 14 de agosto de 2018**. Lei Geral de Proteção de Dados Pessoais (LGPD). Brasília, DF: Presidência da República, 2018. Disponível em: <http://www.planalto.gov.br/ccivil_03/_ato2015-2018/2018/lei/l13709.htm>. Acesso em: 18 out. 2026.

CENTER FOR INTERNET SECURITY (CIS). **CIS Critical Security Controls Version 8**: Control 3 (Data Protection) and Control 16 (Application Software Security). East Greenbush: CIS, 2021. Disponível em: <https://www.cisecurity.org/controls>. Acesso em: 18 out. 2026.

GALEGALE, Napoleão Verardi; FONTES, Edison Luiz Gonçalves; GALEGALE, Bernardo Perri. Uma contribuição para a segurança da informação: um estudo de casos múltiplos com organizações brasileiras. **Perspectivas em Ciência da Informação**, Belo Horizonte, v. 22, n. 3, p. 75-97, 2017. Disponível em: <https://www.scielo.br/j/pci/a/Srp97XX3Hyb4MfjxRH9gDgd/>. Acesso em: 18 out. 2026.

GODOY, Arilda Schmidt. Introdução à pesquisa qualitativa e suas possibilidades. **Revista de Administração de Empresas**, São Paulo, v. 35, n. 2, p. 57-63, 1995. Disponível em: <https://doi.org/10.1590/S0034-75901995000200008>. Acesso em: 18 out. 2026.

GOVERNO DIGITAL (BRASIL). **Guia sobre Privacidade desde a Concepção e por Padrão (Privacy by Design e by Default)**. Brasília, DF: Secretaria de Governo Digital, 2024.

INTERNATIONAL ORGANIZATION FOR STANDARDIZATION (ISO). **ISO/IEC 27001:2022**: Information security, cybersecurity and privacy protection — Information security management systems — Requirements. Geneva: ISO, 2022. Disponível em: <https://www.iso.org/standard/27001>. Acesso em: 18 out. 2026.

LIMA, Telma Cristiane Sasso de; MIOTO, Regina Célia Tamaso. Procedimentos metodológicos na construção do conhecimento científico: a pesquisa bibliográfica. **Revista Katálysis**, Florianópolis, v. 10, n. esp., p. 37-45, 2007. Disponível em: <https://doi.org/10.1590/S1414-49802007000300004>. Acesso em: 18 out. 2026.

NATIONAL INSTITUTE OF STANDARDS AND TECHNOLOGY (NIST). **Secure Software Development Framework (SSDF) Version 1.1**: Recommendations for Mitigating the Risk of Software Vulnerabilities. NIST Special Publication 800-218. Gaithersburg: NIST, 2022. Disponível em: <https://doi.org/10.6028/NIST.SP.800-218>. Acesso em: 18 out. 2026.

OPEN WORLDWIDE APPLICATION SECURITY PROJECT (OWASP). **Application Security Verification Standard (ASVS) Version 5.0**. OWASP Foundation, 2026. Disponível em: <https://owasp.org/www-project-application-security-verification-standard/>. Acesso em: 18 out. 2026.

OPEN WORLDWIDE APPLICATION SECURITY PROJECT (OWASP). **OWASP Top 10:2021 - The Ten Most Critical Web Application Security Risks**. OWASP Foundation, 2021. Disponível em: <https://owasp.org/Top10/>. Acesso em: 18 out. 2026.

OPEN WORLDWIDE APPLICATION SECURITY PROJECT (OWASP). **Password Storage Cheat Sheet**. OWASP Cheat Sheet Series, 2026. Disponível em: <https://cheatsheetseries.owasp.org/cheatsheets/Password_Storage_Cheat_Sheet.html>. Acesso em: 18 out. 2026.

OPEN WORLDWIDE APPLICATION SECURITY PROJECT (OWASP). **Web Security Testing Guide (WSTG) Version 4.2**. OWASP Foundation, 2026. Disponível em: <https://owasp.org/www-project-web-security-testing-guide/>. Acesso em: 18 out. 2026.

QUEIROZ, Danielle. A adequação à Lei Geral de Proteção de Dados Pessoais em instituições de ensino superior: um estudo multicasos. **Perspectivas em Ciência da Informação**, Belo Horizonte, 2021. Disponível em: <https://www.scielo.br/j/pci/a/fXymQSs7w6D5pSMSmCtrPbf/>. Acesso em: 18 out. 2026.

SFREDDO, Josiane Ayres; FLORES, Daniel. Segurança da informação arquivística: o controle de acesso em arquivos públicos estaduais. **Perspectivas em Ciência da Informação**, Belo Horizonte, 2012. Disponível em: <https://www.scielo.br/j/pci/a/mZKkFG8BBGHxztZvZNzRbMR/>. Acesso em: 18 out. 2026.

ANEXOS

Anexo I – Matriz de Requisitos Mínimos de Segurança e Privacidade do Sistema Windol (DEVSEG Anexo D)

Quadro 3 – Matriz Resumida de Requisitos de Segurança (DEVSEG Anexo D)

ID	Categoria	Descrição do Requisito	Origem Normativa	Critério de Verificação
RS-001	Identidade	Identificação unívoca do usuário em sessão ativa	DEVSEG D.5.1 / ASVS V2	Sessão válida em todas as requisições
RS-002	Autenticação	Autenticação mandatória para todas as rotas operacionais	DEVSEG D.5.1 / ASVS V2	Bloqueio de acesso não autenticado
RS-003	Autorização	Controle de acesso por perfil (RBAC) validado no backend	DEVSEG D.5.1 / ASVS V4	Decoradores de rota no servidor
RS-004	Senhas	Armazenamento de senhas com algoritmo de hash e salt	DEVSEG D.5.2 / ASVS V2	Hash PBKDF2:SHA-256 no banco SQLite
RS-005	Segredos	SECRET_KEY obtida via variáveis de ambiente	DEVSEG 11.6 / CIS 16.4	Ausência de chave hardcoded no código
RS-006	Hardening	Desativação de modo debug em execução operacional	DEVSEG 16.3 / CIS 16.7	debug=False e telas de erro genéricas
RS-007	Minimização	Coleta e exibição apenas dos dados necessários	LGPD Art. 6º, III / CIS 3	Telas com campos restritos por perfil
RS-008	Auditoria	Registro em banco de dados de eventos críticos de segurança	DEVSEG D.5.3 / CIS 16	Tabela logs_auditoria preenchida

Fonte: Elaborado pelos autores com base no Manual DEVSEG (2026).

Anexo II – Parecer Institucional de Liberação Segura (Go/No-Go - DEVSEG Anexo I)

Em conformidade com as diretrizes do Anexo I do Manual DEVSEG, a versão candidata do Sistema Windol foi submetida à avaliação dos critérios institucionais de aceitabilidade. Constatou-se que todos os requisitos mínimos obrigatórios foram atendidos, os testes de validação funcional e de segurança foram concluídos com êxito e todas as vulnerabilidades críticas bloqueantes identificadas no diagnóstico inicial foram remediadas. Portanto, emite-se o parecer conclusivo de **GO (Aprovado para Liberação)**.